

# ANALISIS DE INSTRUCCIONES CON EL MODELO DIAMANTE

Actividad 18

## Equipo 4

|                                      |         |
|--------------------------------------|---------|
| Bustamante Rocha Cristopher Leonardo | -173754 |
| Cavazos Zacarías Rodolfo             | -178823 |
| Gutiérrez Hernández Rodolfo          | -179598 |
| Morquecho Medina Eduardo Gabriel     | -175805 |
| Nieto Díaz de Leon Jair de Jesus     | -171676 |
| Salazar Hernández Pablo de Jesús     | -171580 |

Profesor Servando López Contreras

# Introducción

El Modelo Diamante de Análisis de Intrusiones es una metodología utilizada en ciberseguridad para analizar ataques informáticos mediante la relación entre cuatro elementos principales: adversario, capacidad, infraestructura y víctima. Este modelo permite comprender cómo opera un atacante, qué herramientas utiliza y cuáles son sus objetivos dentro de una intrusión.

Por otra parte, la Cyber Kill Chain es un modelo desarrollado para describir las diferentes fases de un ciberataque, desde el acceso inicial hasta las acciones finales del atacante sobre el objetivo. La combinación de ambos modelos permite identificar patrones de comportamiento, correlacionar eventos y comprender de manera más clara el desarrollo de una intrusión.

En esta actividad se analizará un escenario de ataque utilizando el Modelo Diamante y la Cyber Kill Chain para identificar los elementos involucrados, las fases del ataque y la posible propagación dentro de la red.

## Parte 1: Comprensión del Modelo

El Modelo Diamante se basa en cuatro nodos interconectados

| ELEMENTO               | DESCRIPCION                                                                                             | EJEMPLO PRACTICO                                                                    |
|------------------------|---------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <b>Adversario</b>      | El actor o grupo responsable del ataque. Puede ser un individuo, una nación-estado o un grupo criminal. | Grupo APT28 (Fancy Bear) o un empleado deshonesto.                                  |
| <b>Capacidad</b>       | Las herramientas, técnicas y procedimientos (TTPs) que utiliza el adversario para ejecutar el evento.   | Malware tipo Ransomware, un exploit de día cero o una campaña de Phishing.          |
| <b>Infraestructura</b> | Los recursos físicos o lógicos que el adversario utiliza para entregar la capacidad o comunicarse.      | Servidores de Comando y Control (C2), direcciones IP, nombres de dominio o proxies. |
| <b>Victima</b>         | El objetivo del ataque. Puede ser una organización, una persona, una dirección                          | El servidor de base de datos de un banco o el correo electrónico de un directivo.   |

## Parte 2: Análisis del Evento

### Escenario

Una organización detecta comportamiento anómalo en un equipo. El análisis revela:

1. La víctima detecta malware.
2. El malware contiene dominios de Comando y Control (C2).
3. Los dominios resuelven a direcciones IP externas.
4. Los logs muestran múltiples hosts conectándose a esas IP.
5. WHOIS/IP revela posible origen del atacante.

### Estructura de Evento

| METACARACTERÍSTICA     | DESCRIPCIÓN DEL EVENTO                                                                              |
|------------------------|-----------------------------------------------------------------------------------------------------|
| <b>Marca de tiempo</b> | Momento en que se detecta el malware y las conexiones sospechosas hacia IP externas.                |
| <b>Fase</b>            | Compromiso inicial, ejecución del malware y comunicación con C2.                                    |
| <b>Resultado</b>       | El equipo fue comprometido y estableció comunicación con infraestructura externa del atacante.      |
| <b>Dirección</b>       | Víctima -> Infraestructura. Tráfico saliente desde los hosts internos hacia dominios e IP externas. |
| <b>Metodología</b>     | Uso de malware con capacidades de comando y control (C2), resolución DNS y conexiones remotas.      |
| <b>Recursos</b>        | Malware, dominios C2, direcciones IP externas, logs de red y registros WHOIS/IP.                    |

## Preguntas del Escenario

### 1. ¿Quién es el adversario en este escenario?

El adversario es un atacante o grupo cibercriminal externo que opera el malware y la infraestructura de comando y control (C2). Su posible origen puede identificarse mediante el análisis WHOIS y el rastreo de direcciones IP externas mencionado en el escenario.

### 2. ¿Cuál es la capacidad utilizada?

La capacidad utilizada es malware con funciones de comunicación C2, diseñado para conectarse a dominios específicos y permitir el control remoto del sistema comprometido. Posiblemente fue distribuido mediante phishing.

### 3. ¿Qué tipo de infraestructura se emplea?

Se emplea infraestructura externa compuesta por dominios maliciosos, servidores de comando y control (C2) y direcciones IP públicas utilizadas para la comunicación con los hosts comprometidos.

### 4. ¿Quién es la víctima primaria?

La víctima primaria es el equipo o usuario de la organización donde inicialmente se detectó el comportamiento anómalo y el malware.

### 5. ¿Existe evidencia de movimiento lateral?

Sí. Los logs muestran múltiples hosts conectándose a las mismas IP externas, lo que sugiere posible propagación del malware o movimiento lateral dentro de la red interna.

## Parte 3: Relación Con la Kill Chain

### EVENTO

Detección de Malware

Envío de Phishing

Conexión a C2

Ejecucion de Malware

### FASE KILL CHAIN

Instalación / Acciones sobre el objetivo

Entrega (Delivery)

Comando y Control (C2)

Explotación

## Parte 4: Hilos de actividad (Pivoting)

### Hilo 1 – Víctima 1

- El atacante envía un correo de phishing dirigido al administrador.
- El administrador abre el archivo o enlace malicioso.
- Se ejecuta el malware en el equipo comprometido.
- El malware establece conexión con el servidor C2.
- El atacante obtiene acceso remoto al host.

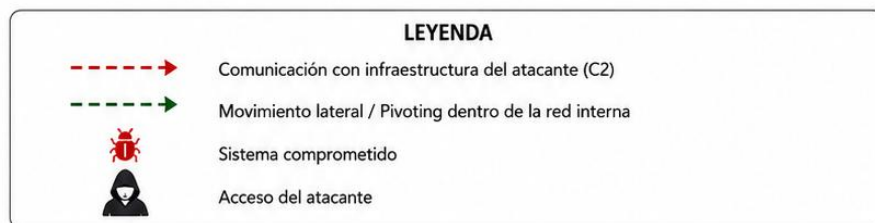
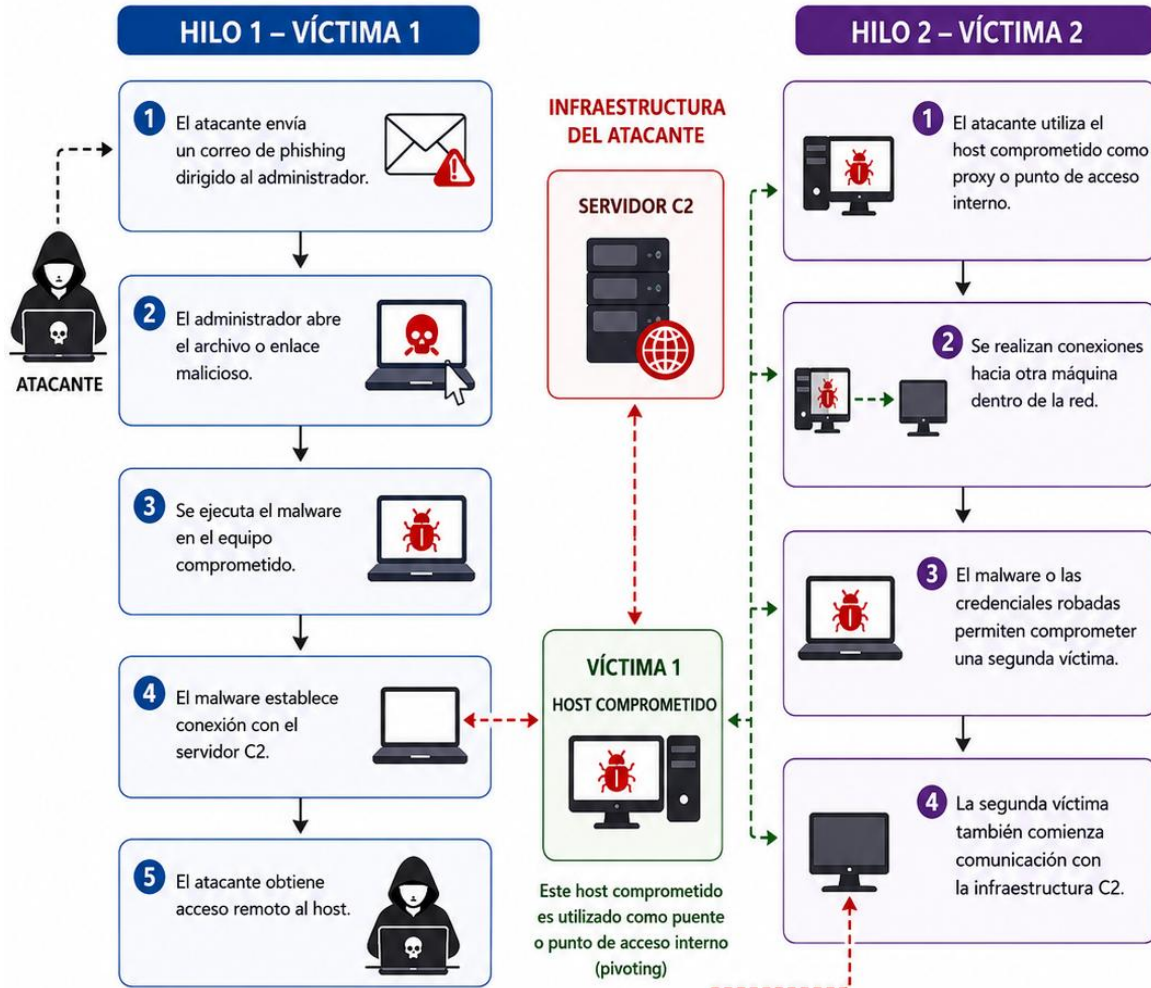
## **Hilo 2 – Víctima 2**

1. El atacante utiliza el host comprometido como proxy o punto de acceso interno.
2. Se realizan conexiones hacia otra máquina dentro de la red.
3. El malware o las credenciales robadas permiten comprometer una segunda víctima.
4. La segunda víctima también comienza comunicación con la infraestructura C2.

## **Relación entre ambos (Pivoting)**

El pivoting ocurre cuando el atacante utiliza el primer equipo comprometido para desplazarse lateralmente y atacar otros sistemas dentro de la red. En este caso, la Víctima 1 funciona como puente para comprometer a la Víctima 2.

## HILOS DE ACTIVIDAD Y PIVOTING





## Conclusión

El análisis realizado mediante el Modelo Diamante permitió identificar la relación entre el atacante, las capacidades utilizadas, la infraestructura maliciosa y las víctimas afectadas. Asimismo, la Cyber Kill Chain facilitó comprender las diferentes fases del ataque y detectar indicios de movimiento lateral dentro de la red. El estudio de los hilos de actividad demostró cómo un host comprometido puede utilizarse para realizar pivoting y expandir la intrusión hacia otros sistemas. Este tipo de metodologías son fundamentales para mejorar la detección, análisis y respuesta ante incidentes de ciberseguridad.